

INFORME DE ESTADO DE SEGURIDAD

BootWhatsapp

CRM y Bot de WhatsApp multi-empresa · Plataforma Django/DRF

Fecha	8 de julio de 2026
Tipo	Evaluación de postura de seguridad y mapeo de la plataforma
Alcance	Backend, API pública (gateway), webhook de mensajería, pipeline de IA, capa de datos, despliegue e infraestructura
Superficie	151 rutas de API · 27 entidades de datos · 29 módulos de servicio · 11 secciones con control de acceso

A**Postura de seguridad: Sólida.**

Plataforma madura con defensa en profundidad en todas las capas: aislamiento multi-empresa, control de acceso por rol, cifrado de credenciales, firmas criptográficas y protección de la IA frente a fugas de datos.

Documento de estado para uso interno y presentación a dirección. Resume la arquitectura de la plataforma y el nivel de protección de cada componente.

1. Panorama general

BootWhatsapp es una plataforma **multi-empresa** (multi-tenant) que integra un CRM, un bot de atención por WhatsApp asistido por IA, una API para aliados externos y flujos operativos de validación y salidas. Este informe presenta el mapa de sus componentes y evalúa qué tan bien protegida está cada parte.

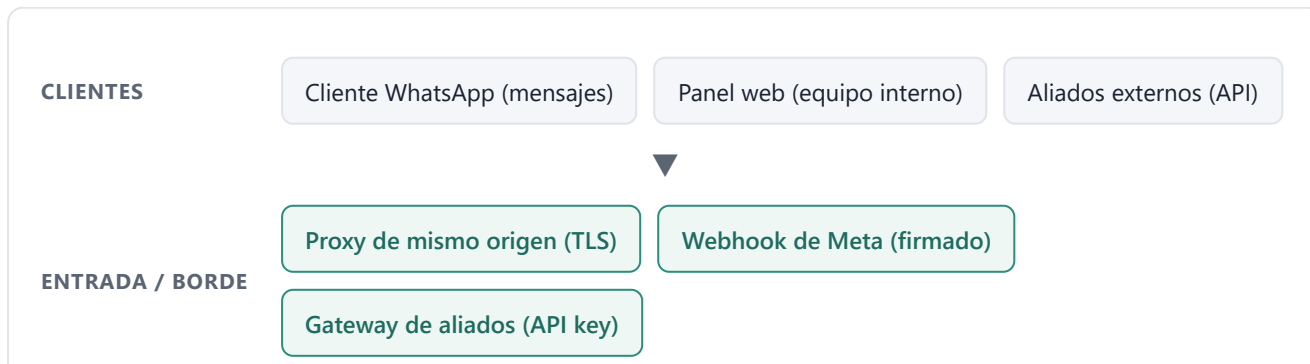
A CALIFICACIÓN GLOBAL	7 DOMINIOS DE SEGURIDAD EVALUADOS	11 SECCIONES CON RBAC	100% DATOS AISLADOS POR EMPRESA
---------------------------------	---	---------------------------------	---

La evaluación cubrió siete dominios de seguridad. Todos obtienen una valoración de **Sólido o Excelente**: el diseño aplica los patrones correctos de forma consistente (verificación fail-closed, comparaciones en tiempo constante, cifrado de secretos en reposo, y un único punto de control para todo lo que sale hacia el cliente).

Dominio de seguridad	Valoración	Base de la valoración
Autenticación e identidad	Sólido	Tokens firmados con clave dedicada, rotación y revocación de sesiones
Control de acceso (RBAC)	Sólido	Permisos por rol y por sección aplicados en la API, no solo en la interfaz
Aislamiento multi-empresa	Excelente	Todo dato queda acotado a su empresa; acceso fail-closed
API pública / integraciones	Sólido	Llaves con hash, permisos por sección, límite de uso
Mensajería y webhook	Excelente	Firma criptográfica verificada en tiempo constante
Protección de la IA / bot	Excelente	Punto único de control de salida; sin fugas de datos internos
Secretos, cifrado y despliegue	Sólido	Credenciales cifradas en reposo; configuración endurecida

2. Mapa de la plataforma

Componentes principales y cómo fluye una petición desde el exterior hasta los datos.





Toda petición externa atraviesa la capa de **Controles** antes de llegar a la aplicación: primero se autentica, luego se comprueba el permiso de sección del usuario y, por último, cualquier consulta a datos queda acotada a la empresa del solicitante. Las credenciales de terceros y los documentos de los clientes nunca se sirven sin una capa de protección (cifrado o firma).

3. Evaluación por dominio

Aislamiento multi-empresa

Excelente

Es la garantía central de una plataforma multi-tenant: los datos de una empresa nunca deben ser visibles para otra.

- ✓ Cada consulta de datos se acota automáticamente a la empresa del usuario.
- ✓ El acceso es **fail-closed**: un usuario sin empresa asociada es rechazado, no degradado a un acceso genérico.
- ✓ La ficha de cada cliente queda aislada incluso por línea de WhatsApp: el mismo teléfono en dos números distintos son dos expedientes independientes.
- ✓ Los documentos y la mensajería se filtran por empresa y por conversación en todo momento.

Control de acceso por rol (RBAC)

Sólido

La plataforma distingue roles operativos (administración, agentes, validación, liquidación, salidas, inventario vehicular y aliados) con permisos granulares sobre 11 secciones.

- ✓ Los permisos se aplican **en la API**, no solo ocultando botones en la interfaz.
- ✓ Cada usuario puede tener un rol principal y uno secundario, sumando permisos de forma controlada.
- ✓ La administración del equipo tiene barreras anti-escalada: nadie puede concederse privilegios de administrador ni editar cuentas de mayor nivel.
- ✓ Los permisos se guardan de forma completa y autoritativa, evitando que un permiso retirado reaparezca por un valor por defecto.

Protección de la IA y del bot

Excelente

El bot responde a clientes externos con un modelo de lenguaje. El riesgo central —que filtre datos internos (liquidaciones, notas, secretos, datos de otros clientes)— está mitigado con varias capas.

- ✓ **Punto único de control de salida:** todo texto que sale hacia el cliente pasa por un mismo filtro que redacta secretos, aplicado además en el envío final como red de seguridad.
- ✓ El contexto que recibe el modelo contiene solo lo imprescindible; las notas internas y los cálculos confidenciales nunca entran al prompt.
- ✓ Los datos confidenciales de una liquidación están marcados de forma que el sistema falla ruidosamente si algún flujo intenta enviarlos al cliente.
- ✓ La entrada del cliente se sanitiza (se neutralizan intentos de manipular las instrucciones del modelo).
- ✓ Existe una batería de 105 pruebas automatizadas, con cinco suites dedicadas específicamente a detectar fugas de información.

Mensajería y webhook (Meta / WhatsApp)

Excelente

- ✓ Cada mensaje entrante se valida con una **firma criptográfica** comparada en tiempo constante antes de procesarse.
- ✓ Un mensaje cuyo origen no corresponde a una línea dada de alta se descarta, sin asignarlo a ninguna empresa por error.
- ✓ Las descargas de contenido multimedia se limitan y se validan contra los servidores oficiales de la plataforma de mensajería.

API pública para aliados**Sólido**

- ✓ Autenticación por llave de API almacenada como **hash con sal** (nunca en texto plano) y comparada en tiempo constante.
- ✓ Cada llave tiene permisos por sección: un aliado solo ve los datos que se le habilitaron.
- ✓ Toda respuesta queda acotada a la empresa dueña de la llave.
- ✓ Límite de uso por llave para frenar abusos.

Autenticación e identidad**Sólido**

- ✓ Sesiones basadas en tokens firmados con una **clave dedicada**, independiente del resto de la configuración.
- ✓ Rotación de tokens y capacidad de **revocar sesiones** (un acceso comprometido o un usuario dado de baja deja de poder renovar su sesión).
- ✓ Cookies con las marcas de seguridad adecuadas y política de mismo origen.

Secretos, cifrado y despliegue**Sólido**

- ✓ Las credenciales de terceros se guardan **cifradas en reposo** en la base de datos, con soporte de rotación de la clave de cifrado.
- ✓ El código no contiene secretos incrustados; el historial de control de versiones está limpio de credenciales.
- ✓ Los documentos de los clientes se sirven mediante **enlaces firmados y con caducidad**, con protección contra recorrido de rutas y contra la ejecución de contenido malicioso.
- ✓ Configuración de producción endurecida: sin modo depuración, dominios permitidos acotados y políticas de origen cerradas por defecto.

4. Controles de seguridad presentes

Resumen de los mecanismos de protección verificados en la plataforma.

Control	Cómo protege
Aislamiento por empresa (fail-closed)	Impide que una empresa acceda a datos de otra, incluso manipulando identificadores.
RBAC por sección en la API	Limita cada rol a las funciones que le corresponden, aplicado en el servidor.
Firmas criptográficas (HMAC)	Garantizan que los mensajes de mensajería y los callbacks internos son auténticos.
Comparaciones en tiempo constante	Evitan que un atacante deduzca secretos midiendo tiempos de respuesta.

Control	Cómo protege
Cifrado de credenciales en reposo	Protege los tokens de terceros aunque se acceda a la base de datos.
Portero único de salida del bot	Redacta cualquier secreto antes de que un mensaje llegue al cliente.
Enlaces de media firmados y con caducidad	Evita el acceso no autorizado a documentos de clientes.
Protección contra acceso a recursos internos	Bloquea que las consultas a fuentes externas apunten a la red interna.
Límite de uso por llave / origen	Frena el abuso y la extracción masiva de datos.
Revocación de sesiones	Permite cortar el acceso de una sesión o usuario comprometido.
Suite de pruebas anti-fugas	Congela el comportamiento seguro: cualquier regresión se detecta automáticamente.

5. Conclusión

La plataforma presenta una **postura de seguridad sólida**, con una calificación global de **A**. La arquitectura aplica de forma consistente los patrones adecuados en todas sus capas: el aislamiento entre empresas es completo y a prueba de fallos, el control de acceso se hace valer en el servidor y no solo en la interfaz, las comunicaciones con la plataforma de mensajería y con los aliados están autenticadas criptográficamente, las credenciales sensibles están cifradas, y el bot de IA cuenta con un mecanismo dedicado que impide la fuga de información interna hacia los clientes.

La existencia de una batería de pruebas automatizadas centrada en la seguridad —en particular en la prevención de fugas de datos— es una señal de madurez: garantiza que las protecciones se mantienen intactas a medida que la plataforma evoluciona.

Evaluación realizada mediante revisión de la arquitectura y el código de la plataforma en siete dominios de seguridad (identidad, control de acceso, aislamiento multi-empresa, API pública, mensajería, protección de IA, y secretos/despliegue), complementada con la ejecución de la suite de pruebas automatizadas. — Informe generado el 8 de julio de 2026.